

INDEX

- **Operation Wocao — Campaign Research Report**
 - **MITRE ATT&CK Campaign ID: C0014**
 - **INTERN ID : 2114**
-

<u>S.No.</u>	<u>Section</u>
1	Campaign Overview
2	Threat Actor / Group Association
3	Timeline
4	Objectives of Attack
5	Targeted Sectors & Countries
6	Attack Flow
7	MITRE ATT&CK Techniques Used
8	Real-World Incidents
9	Detection Opportunities
10	Defensive Recommendations
11	Indicator Of Compromise(IOCs)
12	Tools And Malware Used
13	Research Analysis
14	References
15	Conclusion

➤ 1.Campaign Overview:Operation Wocao

Operation Wocao was a large-scale cyber espionage campaign that targeted organizations across multiple countries and industries **between December 2017 and December 2019**. The campaign mainly focused on stealing sensitive information, maintaining long-term access inside victim environments, and conducting advanced reconnaissance activities.

The campaign targeted countries including Brazil, China, France, Germany, Italy, Mexico, Portugal, Spain, the United Kingdom, and the United States. Victims included government organizations, managed service providers, aviation companies, finance sectors, healthcare industries, software development companies, transportation companies, and energy sectors.

Security researchers observed that the threat actors used tactics, techniques, and procedures (TTPs) similar to those used by APT20, suggesting a possible overlap between the two groups. The campaign name “Operation Wocao” originated from a command-line entry found during forensic investigation.

Official link: <https://attack.mitre.org/campaigns/C0014>

ID: C0014

First Seen: December 2017 ^[1]

Last Seen: December 2019 ^[1]

Contributors: Erik Schamper,
@Schamperr, Fox-IT; Maarten van
Dantzig, @MaartenVDantzig, Fox-IT

Version: 1.2

Created: 27 September 2022

Last Modified: 12 May 2026

➤ 2. Threat Actor / Group Association

Researchers believe that Operation Wocao was conducted by suspected China-based threat actors. The attackers demonstrated advanced persistence techniques, stealth operations, and professional cyber espionage methodologies.

The campaign showed similarities with the activities of **APT20** due to overlapping tools, attack techniques, infrastructure usage, and operational behavior patterns. The attackers used custom malware, webshells, credential dumping tools, and remote administration techniques to maintain long-term access within compromised systems.

Primary Reference: Fox-IT Report — *"Operation Wocao: Shining a light on one of China's hidden hacking groups"* (December 19, 2019)

➤ THREAT ACTOR / GROUP ASSOCIATION

Field	Details
Suspected Origin	China (China-based actors)
Possible Overlap	APT20
Attribution Confidence	Moderate (TTPs & tool similarity)
Actor Type	State-sponsored / Cyber Espionage
Infrastructure	Bitcoin se purchase kiye gaye servers

Official link: [201912_report_operation_wocao.pdf](#)



➤ **3. Timeline**

<u>Year</u>	<u>Activity</u>
December 2017	Initial malicious activity identified
2018	Large-scale compromise of organizations worldwide
2018	Credential theft and lateral movement activities detected
2019	Security researchers publicly documented the campaign
December 2019	Final known activity observed

➤ **4. Objectives of the Attack**

The main objectives of Operation Wocao included:

- Cyber espionage
- Sensitive data theft
- Maintaining persistent access
- Intelligence gathering
- Credential theft
- Monitoring victim environments
- Accessing confidential organizational information

The attackers focused on obtaining strategic and operational intelligence from targeted organizations.

➤ 5. Targeted Sectors and Countries

Targeted Countries

- Brazil
- China
- France
- Germany
- Italy
- Mexico
- Portugal
- Spain
- United Kingdom
- United States

4 Victims

Fox-IT has identified dozens of victims across the world, including in Brazil, China, France, Germany, Italy, Mexico, Portugal, Spain, United Kingdom and the United States.

Figure 3 – World map with geographical locations of victims



Targeted Industries

- Government
 - Aviation
 - Construction
 - Energy
 - Finance
 - Healthcare
 - Insurance
 - Offshore Engineering
 - Software Development
 - Transportation
-

➤ 6. Attack Flow

[Initial Access]

---↓

JBoss Server Exploitation (T1190) / VPN with Stolen Credentials (T1133/T1078)

---↓

[Execution]

---↓

Web Shell Deploy + PowerShell / CMD / Python Backdoors (T1059.001/003/006)

---↓

[Persistence]

---↓

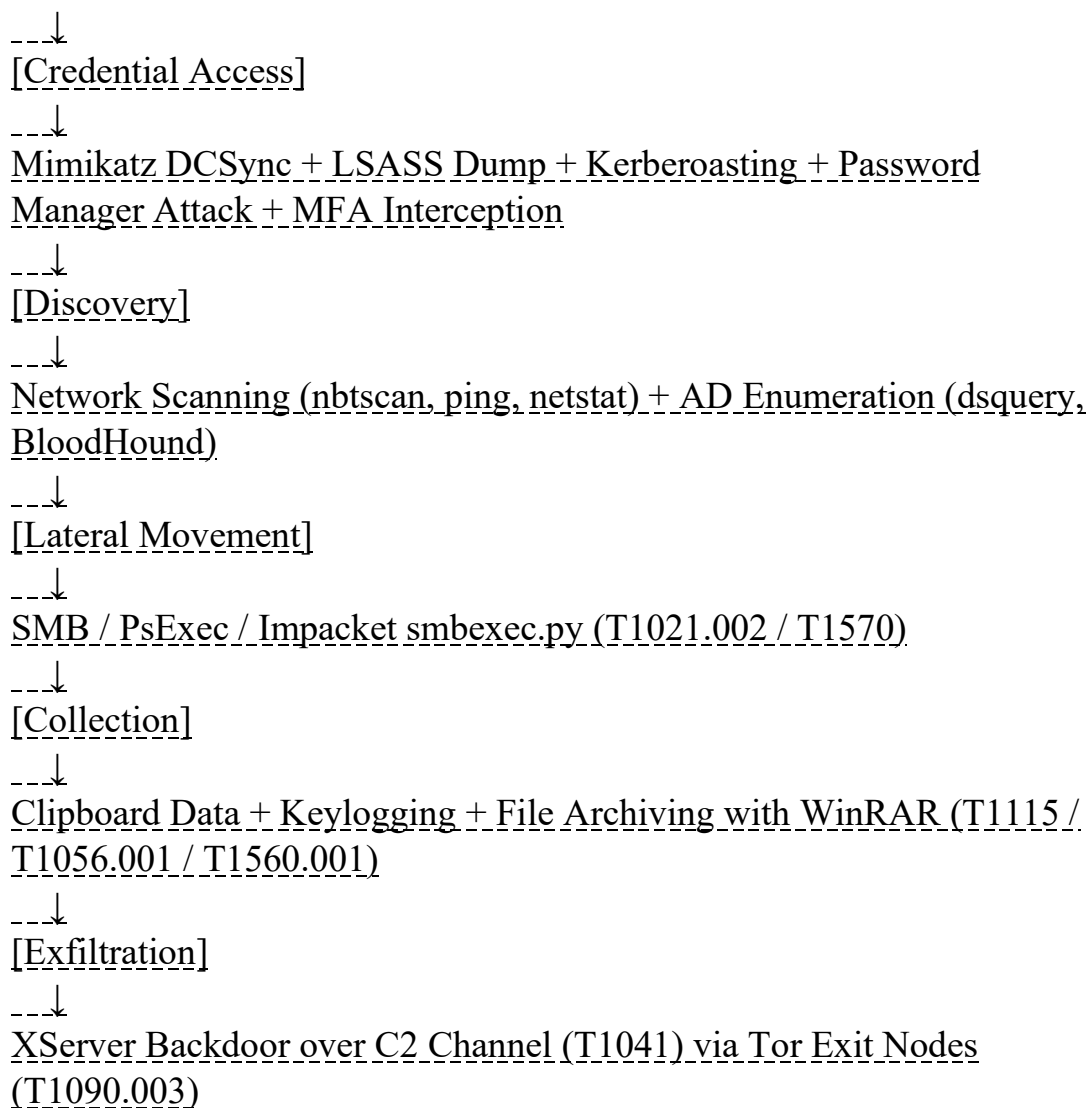
Scheduled Tasks (T1053.005) + Service Creation (T1569.002)

---↓

[Defense Evasion]

---↓

Event Log Clearing + File Deletion + Masquerading + Command Obfuscation (T1070/T1036)



❖ EXPLANATION

Step 1 – Initial Access

Threat actors exploited vulnerabilities in public-facing applications such as JBoss web servers. They also used stolen VPN credentials for unauthorized access.

Step 2 – Webshell Deployment

Custom webshells were uploaded to compromised servers to establish persistence and remote command execution capabilities.

Step 3 – Credential Access

Attackers used credential dumping tools like Mimikatz and ProcDump to extract credentials from LSASS memory and Windows certificate stores.

Step 4 – Discovery

The attackers collected information about:

- Network configuration
- Open ports
- User accounts
- System services
- Domain trusts
- Internet connectivity

Step 5 – Lateral Movement

Tools such as PsExec, WMI, and Impacket were used to move across systems within the network.

Step 6 – Data Collection

Sensitive files and directories were collected and staged in temporary folders.

Step 7 – Exfiltration

The attackers exfiltrated stolen data over encrypted command-and-control channels using HTTP/HTTPS protocols.



Initial Access

Drive-by Compromise
Exploit Public-Facing Application
 Hardware Additions
 Replication Through Removable Media
 Spearphishing Attachment
 Spearphishing Link
 Spearphishing via Service
 Supply Chain Compromise
 Trusted Relationship
 Valid Accounts



Execution

AppleScript
 CMSTP
Command-Line Interface
 Compiled HTML File
 Control Panel Items
 Dynamic Data Exchange
 Execution through API
 Execution through Module Load
 Exploitation for Client Execution
 Graphical User Interface
 InstallUtil
 Launchctl
 Local Job Scheduling
 LSASS Driver
 Mshta
PowerShell
 Regsvcs/Regasm
 Regsvr32
 Rundll32
Scheduled Task
 Scripting
Service Execution
 Signed Binary Proxy Execution
 Signed Script Proxy Execution
 Source
 Space after Filename
 Third-party Software
 Trap
 Trusted Developer Utilities
 User Execution
Windows Management Instrumentation
 Windows Remote Management
 XSL Script Processing



Persistence

.bash_profile and .bashrc
 Accessibility Features
 Account Manipulation
 AppCert DLLs
 Appinit DLLs
 Application Shimming
 Authentication Package
 BITS Jobs
 Bootkit
 Browser Extensions
 Change Default File Association
 Component Firmware
 Component Object Model Hijacking
 Create Account
 DLL Search Order
 Hijacking
 Dylib Hijacking
External Remote Services
 File System Permissions Weakness
 Hidden Files and Directories
 Hooking
 Hypervisor
 Image File Execution Options Injection
 Kernel Modules and Extensions
 Launch Agent
 Launch Daemon
 Launchctl
 LC_LOAD_DYLIB Addition
 Local Job Scheduling
 Login Item
 Login Scripts
 LSASS Driver
 Modify Existing Service
 Netsh Helper DLL
 New Service
 Office Application Startup
 Path Interception
 Plist Modification
 Port Knocking
 Port Monitors
 Rc.common
 Re-opened Applications
 Redundant Access
 Registry Run Keys / Startup Folder
 Scheduled Task
 Screensaver
 Security Support Provider
 Service Registry



Privilege Escalation

Access Token Manipulation
 Accessibility Features
 AppCert DLLs
 Appinit DLLs
 Application Shimming
 Bypass User Account Control
 DLL Search Order
 Hijacking
 Dylib Hijacking
 Exploitation for Privilege Escalation
 Extra Window Memory Injection
 File System Permissions Weakness
 Hooking
 Image File Execution Options Injection
 Launch Daemon
 New Service
 Path Interception
 Plist Modification
 Port Monitors
Process Injection
 Scheduled Task
 Service Registry
 Permissions Weakness
 Setuid and Setgid
 SID-History Injection
 Startup Items
 Sudo
 Sudo Caching
Valid Accounts
 Web Shell



Defense Evasion

Access Token Manipulation
 Binary Padding
 BITS Jobs
 Bypass User Account Control
 Clear Command History
 CMSTP
 Code Signing
 Compiled HTML File
 Component Firmware
 Component Object Model Hijacking
 Control Panel Items
 DCShadow
 Deobfuscate/Decode Files or Information
 Disabling Security Tools
 DLL Search Order Hijacking
 DLL Side-Loading
 Exploitation for Defense Evasion
 Extra Window Memory Injection
File Deletion
 File Permissions Modification
 File System Logical Offsets
 Gatekeeper Bypass
 Hidden Files and Directories
 Hidden Users
 Hidden Window
 HISTCONTROL
 Image File Execution Options Injection
 Indicator Blocking
Indicator Removal from Tools
Indicator Removal on Host
 Indirect Command Execution
 Install Root Certificate
 InstallUtil
 Launchctl
 LC_MAIN Hijacking
 Masquerading
Modify Registry
 Mshta
 Network Share
 Connection Removal
 NTFS File Attributes
Obfuscated Files or Information



Credential Access

Account Manipulation
 Bash History
 Brute Force
Credential Dumping
 Credentials in Files
 Credentials in Registry
 Exploitation for Credential Access
 Forced Authentication
 Hooking
Input Capture
 Input Prompt
Kerberoasting
 Keychain
 LLMNR/NBT-NS Poisoning
 Network Sniffing
 Password Filter DLL
Private Keys
 Securityd Memory
 Two-Factor Authentication
 Interception

➤ 7. MITRE ATT&CK Techniques Used

<u>Technique ID</u>	<u>Technique Name</u>	<u>Purpose</u>
T1190	Exploit Public-Facing Application	Initial access
T1078	Valid Accounts	Unauthorized login
T1003.001	OS Credential Dumping: LSASS Memory	Credential theft
T1047	Windows Management Instrumentation	Remote execution
T1071.001	Application Layer Protocol: Web Protocols	C2 communication
T1041	Exfiltration Over C2 Channel	Data theft
T1087.002	Domain Account Discovery	User enumeration
T1016	System Network Configuration Discovery	Reconnaissance
T1059.001	PowerShell	Command execution
T1558.003	Kerberoasting	Password cracking
T1027.010	Command Obfuscation	Defense evasion
T1569.002	Service Execution	Remote execution
T1571	Non-Standard Port	Hidden communication
T1005	Data from Local System	File collection

➤ **8. Real-World Incidents**

Researchers discovered that Operation Wocao actors compromised organizations globally using sophisticated attack techniques.

The attackers exploited JBoss vulnerabilities to gain access to enterprise environments. After gaining access, they deployed webshells, dumped credentials, escalated privileges, and performed lateral movement across internal networks.

Security analysts also observed the use of encrypted communication channels, customized malware, and open-source offensive security tools to evade detection and maintain long-term persistence.

➤ **9. Detection Opportunities**

Organizations can detect similar attacks by monitoring:

- Suspicious VPN login attempts
- Abnormal PowerShell execution
- WMI-based remote execution
- Credential dumping activity
- Unusual use of PsExec
- Unauthorized service creation
- Encoded PowerShell commands
- Unexpected outbound HTTP/HTTPS traffic
- Webshell file creation on servers
- Event log clearing activity using Wevtutil

Security teams should deploy SIEM solutions, EDR tools, IDS/IPS systems, and centralized logging for effective monitoring.

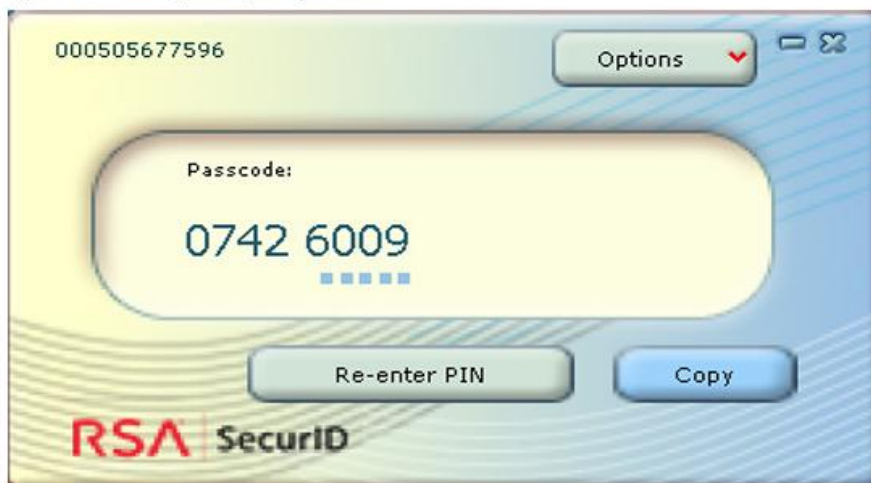


The software token is generated for a specific system, but of course this system specific value could easily be retrieved by the actor when having access to the system of the victim.

As it turns out, the actor does not actually need to go through the trouble of obtaining the victim's system specific value, because this specific value is only checked when importing the SecurID Token Seed, and has no relation to the seed used to generate actual 2-factor tokens. This means the actor can actually simply patch the check which verifies if the imported soft token was generated for this system, and does not need to bother with stealing the system specific value at all.

In short, all the actor has to do to make use of the 2 factor authentication codes is to steal an RSA SecurID Software Token and to patch 1 instruction, which results in the generation of valid tokens:

Figure 8 – RSA SecurID generating valid 2 factor codes



➤ **10. Defensive Recommendations**

❖ **Recommended Security Controls**

1. Multi-Factor Authentication (MFA)

Enable MFA for VPNs, administrator accounts, and remote access systems.

2. Patch Management

Continuously patch public-facing applications and internet-exposed servers.

3. Endpoint Detection and Response (EDR)

Deploy EDR solutions to detect credential dumping, lateral movement, and suspicious command execution.

4. Network Segmentation

Separate sensitive systems from general user networks.

5. Principle of Least Privilege

Restrict administrative access to only required personnel.

6. Log Monitoring

Monitor Windows Event Logs, PowerShell logs, and network traffic for suspicious activity.

7. Webshell Detection

Regularly scan web servers for unauthorized scripts and webshell indicators.

8. Threat Hunting

Use MITRE ATT&CK mapping to proactively hunt for adversary behaviors.

➤ **11. Indicators of Compromise (IOCs)**

❖ **Common IOCs Observed**

- Suspicious PowerShell execution
- Unauthorized VPN logins
- Presence of webshell files
- Use of uncommon ports such as 25667 and 47000
- Abnormal use of WMI and PsExec
- Encoded or obfuscated PowerShell commands
- Event log deletion activity
- Unexpected outbound encrypted traffic

➤ **12. Tools and Malware Used**

<u>Tool</u>	<u>Purpose</u>
<u>Mimikatz</u>	Credential dumping
<u>BloodHound</u>	Active Directory reconnaissance
<u>Impacket</u>	Lateral movement
<u>PsExec</u>	Remote execution
<u>PowerSploit</u>	Kerberoasting
<u>Tor</u>	Anonymous communication
<u>Wevtutil</u>	Log deletion

<u>Tool</u>	<u>Purpose</u>
<u>netstat</u>	Network discovery
<u>dsquery</u>	Active Directory enumeration

➤ 13. Research Analysis

Operation Wocao demonstrates how advanced threat actors combine legitimate administrative tools, open-source offensive frameworks, and custom malware to conduct long-term cyber espionage campaigns.

The campaign heavily relied on:

- Credential theft
- Lateral movement
- Living-off-the-land techniques
- Webshell persistence
- Encrypted command-and-control communication

The attackers showed strong operational discipline and advanced understanding of enterprise environments. The use of MITRE ATT&CK techniques allows defenders to better understand attacker behavior patterns and improve threat detection capabilities.

➤ 14. References

- [MITRE ATT&CK – Operation Wocao](#)
- [MITRE ATT&CK Official Website](#)
- [MITRE ATT&CK Software Database](#)
- [MITRE ATT&CK Research Paper](#)

- Dantzig, M. v., Schamper, E. (2019, December 19). Operation Wocao: Shining a light on one of China's hidden hacking groups. Retrieved October 8, 2020.

Here is your **ready-to-paste Conclusion in English:**

➤ **CONCLUSION**

Operation Wocao — Campaign C0014

Aspect	Summary
Campaign Type	Advanced Cyber Espionage
Duration	December 2017 — December 2019 (2 Years)
Attributed To	Suspected China-Based Threat Actors (APT20 Overlap)
Scale	10+ Countries, 10+ Sectors
Techniques Used	60+ MITRE ATT&CK Techniques
Primary Goal	Credential Theft, Data Exfiltration, Persistent Access

Operation Wocao was a highly sophisticated and long-running cyber espionage campaign that remained active from December 2017 to December 2019, spanning a period of approximately two years. The campaign was conducted by suspected China-based threat actors whose tactics, techniques, and procedures (TTPs) showed significant overlap with the known threat group APT20. One of the most defining characteristics of this campaign was its truly global reach — threat actors successfully compromised organizations across more than 10 countries and targeted over 10 different industry sectors, including government institutions, managed service providers, aviation, energy, finance, healthcare, and transportation.

The threat actors demonstrated a highly methodical and disciplined approach throughout the operation. Initial access was primarily gained by exploiting vulnerabilities in public-facing JBoss web servers and through the use of stolen VPN credentials. Once inside the victim environment, the actors deployed custom-developed tools including the XServer backdoor, a multi-hop proxy tool called "Agent," and Python-based malware compiled with py2exe. Alongside their custom toolset, they strategically leveraged well-known open-source and publicly available tools such as Mimikatz, ProcDump, BloodHound, PowerSploit, Impacket, and PsExec to conduct credential dumping, Active Directory enumeration, and lateral movement.

Perhaps the most concerning aspect of Operation Wocao was the actors' demonstrated capability to **bypass Multi-Factor Authentication (MFA)** by intercepting soft tokens, and their ability to compromise **password managers** using a custom keylogger — highlighting an advanced level of operational maturity. To evade detection, actors systematically cleared Windows Event Logs using Wevtutil, deleted and overwrote files to remove forensic traces, obfuscated PowerShell commands using Base64, zlib, and XOR encoding, and routed their command and control traffic through Tor exit nodes. The campaign's very name originates from a frustrated command line entry typed by one of the threat actors upon losing webshell access — a rare human error that gave investigators a unique insight into the adversary.

Key Takeaways:

- | # | Takeaway |
|---|---|
| 1 | Targeting Managed Service Providers (MSPs) is a force-multiplier strategy — one compromise leads to multiple downstream victims |
| 2 | MFA alone is not sufficient — soft token interception is a proven adversarial capability |
| 3 | Credential hygiene and privileged account monitoring are absolutely critical |
| 4 | Centralized logging and SIEM solutions are essential to prevent local log deletion from destroying forensic evidence |

#	Takeaway
5	Threat actors actively modify and customize tools to evade signature-based detection
6	Long-term persistence spanning 2 years highlights the difficulty of detecting low-and-slow intrusions

Final Assessment:

Operation Wocao stands as a textbook example of state-sponsored cyber espionage — characterized by patience, technical depth, operational discipline, and a clear strategic objective. The campaign serves as a strong reminder to the cybersecurity community that **proactive threat hunting, behavioral detection, network segmentation, and centralized log management** are not optional security measures but absolute necessities — particularly for organizations operating within government, critical infrastructure, or managed service provider sectors. The ability of these threat actors to remain undetected for nearly two years across multiple global organizations underscores the evolving and persistent nature of advanced cyber threats in today's threat landscape.

Researched & Documented By: (*Bhoomi Sanjay Wadke*) **Intern ID:** (2114) **Campaign Assigned:** C0014 — Operation Wocao **Submission Date:** 15 May 2026

SOFTWARE RESEARCH DOCUMENTATION

S0140 — S0150 | MITRE ATT&CK® Software Range

Intern ID: (2114) | Software Range Assigned: S0140 – S0150

SOFTWARE 1 — S0140: Shamoon

Field	Details
Name	Shamoon
ATT&CK ID	S0140
Type	Malware
Associated Names	Disttrack
Platform	Windows
Version	2.2

Description

Shamoon is destructive wiper malware first used in 2012 by an Iranian group known as the "Cutting Sword of Justice." Multiple versions have been observed — Shamoon 2 (2016) and Shamoon 3 (2018). It leverages RawDisk and Filerase tools for data wiping. Analysis has linked Shamoon with Kwampirs malware based on shared artifacts and coding patterns.

Threat Actor Association

Actor	Notes
Cutting Sword of Justice (Iranian)	Original Shamoon (2012)
APT33 / Suspected Iran-nexus	Shamoon 2 & 3 variants

Supported Platforms**Platform**

Windows

ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1548.002	Bypass UAC	Disables UAC remote restrictions via registry modification
T1134.001	Token Impersonation/Theft	Impersonates tokens using LogonUser, ImpersonateLoggedOnUser
T1071.001	Web Protocols	Uses HTTP for C2
T1543.003	Windows Service	Creates "ntssrv", "MaintenaceSrv", "hdv_725x" services
T1485	Data Destruction	Overwrites OS files and disk structures with image files
T1486	Data Encrypted for Impact	Has operational mode for encrypting data
T1140	Deobfuscate/Decode	Decrypts ciphertext using XOR + base64
T1561.002	Disk Structure Wipe	Overwrites MBR
T1070.006	Timestomp	Changes file modified time to evade forensics
T1105	Ingress Tool Transfer	Can download executables to victim
T1570	Lateral Tool Transfer	Copies itself to remote machines on network
T1036.004	Masquerade Task/Service	Service named "ntssrv" mimics legitimate Microsoft service

Technique ID	Technique Name	Description
T1112	Modify Registry	Enables RemoteRegistry, disables UAC restrictions
T1027	Obfuscated Files	Contains base64-encoded strings
T1012	Query Registry	Queries registry to identify hard disk partitions
T1021.002	SMB/Windows Admin Shares	Accesses network shares to copy payloads
T1018	Remote System Discovery	Scans C-class subnet of victim's interfaces
T1053.005	Scheduled Task	Uses scheduled task to execute malware
T1082	System Information Discovery	Obtains OS version and keyboard layout
T1016	System Network Config Discovery	Obtains target IP and local network segment
T1569.002	Service Execution	Creates service "ntssrv", spreads via PsExec
T1529	System Shutdown/Reboot	Reboots system after wiping
T1124	System Time Discovery	Obtains system time; activates only after preset date
T1078.002	Domain Accounts	Uses hard-coded domain credentials for share access

Execution Method

Shamoon creates a Windows service (ntssrv) that executes its wiper payload. It spreads via SMB Admin Shares and scheduled tasks.

Persistence Techniques

Creates Windows services (ntssrv, MaintenaceSrv) for persistence.

Privilege Escalation

Bypasses UAC via registry modification (T1548.002).

Defense Evasion

Timestomping (T1070.006), masquerading service names, base64 obfuscation, UAC bypass.

Credential Access

Uses hard-coded domain credentials (T1078.002) for accessing network shares.

Discovery Techniques

Remote system discovery (C-class subnet scan), registry query for disk partitions, system info & network configuration.

Lateral Movement

Copies itself to remote machines via SMB Admin Shares (T1021.002) and PsExec.

Command & Control

HTTP-based C2 (T1071.001).

Exfiltration

Not primarily designed for exfiltration — focused on destruction.

Impact Analysis

Wipes disk structures including MBR, overwrites OS files with image data or random data. Causes complete system inoperability. Reboots victim machine after wiping. Historically targeted Saudi Aramco (2012) — destroyed 35,000+ workstations.

Indicators of Compromise (IOCs)

Type	Indicator
Service Name	ntssrv, MaintenaceSrv, hdv_725x
Registry Key	SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\LocalAccountTokenFilterPolicy = 1
C2 Protocol	HTTP
File Activity	MBR overwrite, OS file overwrite

Detection & Mitigation

Detection	Method
Service Creation	Monitor for unusual service names (ntssrv, MaintenaceSrv)
MBR Write Activity	Alert on raw disk write operations
SMB Lateral Movement	Monitor abnormal Admin Share access
Registry Modification	Alert on UAC policy registry changes
Mitigation	Disable unnecessary SMB shares, monitor disk write operations, use endpoint protection with behavioral detection

References

- MITRE ATT&CK: <https://attack.mitre.org/software/S0140/>
- Palo Alto (Shamoon 2): <https://researchcenter.paloaltonetworks.com/2016/11/unit42-shamoon-2-return-disttrack-wiper/>
- Palo Alto (Shamoon 3): <https://unit42.paloaltonetworks.com/shamoon-3-targets-oil-gas-organization/>

SOFTWARE 2 — S0141: Winnti for Windows

Field	Details
Name	Winnti for Windows
ATT&CK ID	S0141
Type	Malware
Platform	Windows
Version	3.1

Description

Winnti for Windows is a modular Remote Access Trojan (RAT) used by multiple threat groups since at least 2010, including Winnti Group and Aquatic Panda. It is a persistent backdoor with modular plugin architecture. The Linux variant is tracked separately as Winnti for Linux (S0430).

Threat Actor Association

Actor	Notes
Winnti Group (G0044)	Primary user
Aquatic Panda (G0143)	Used for persistent Windows access

Supported Platforms**Platform**

Windows

ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1548.002	Bypass UAC	Uses sysprep UAC bypass variant
T1071.001	Web Protocols	Encapsulated HTTP/S in C2
T1547.001	Registry Run Keys	Adds "wind0ws" registry service for persistence
T1543.003	Windows Service	Sets DLL as new service in registry
T1140	Deobfuscate/Decode	Dropper decrypts and decompresses data blob
T1573.001	Symmetric Cryptography	XOR-encrypted C2 traffic
T1480.001	Environmental Keying	Verifies command line parameter; uses as decryption key

Technique ID	Technique Name	Description
T1083	File and Directory Discovery	Checks for specific files before execution
T1070.004	File Deletion	Deletes DLL components from host
T1070.006	Timestomp	Sets timestamps to match cmd.exe
T1105	Ingress Tool Transfer	Dropper places malicious payloads
T1036.005	Match Legitimate Resource	DLL named ASPNET_FILTER.DLL mimicking legitimate file
T1106	Native API	Creates new processes, starts services via Native API
T1095	Non-Application Layer Protocol	Custom TCP communication
T1027.013	Encrypted/Encoded File	Encrypts and compresses payload
T1027.015	Compression	Encrypts and compresses payload
T1057	Process Discovery	Checks if explorer.exe called its install function
T1090.001	Internal Proxy	HTTP/S C2 mode uses local proxy
T1090.002	External Proxy	HTTP/S C2 mode uses external proxy
T1218.011	Rundll32	Installer loads DLL using rundll32
T1082	System Information Discovery	Determines OS version
T1569.002	Service Execution	Runs as service using svchost.exe

Execution Method

Installer loads DLL via rundll32.exe. Dropper decrypts data blob and runs as Windows service through svchost.exe.

Persistence Techniques

Registry Run key ("wind0ws"), Windows Service via registry DLL entry.

Privilege Escalation

UAC bypass using sysprep variant (T1548.002).

Defense Evasion

Timestomping, file deletion, masquerading DLL names, encrypted/compressed payload, environmental keying.

Credential Access

Not specifically documented in ATT&CK mapping.

Discovery Techniques

File and directory discovery, process discovery, system information discovery.

Lateral Movement

Modular capabilities allow deployment of additional components.

Command & Control

HTTP/S (with local/external proxy support), Custom TCP (T1095), XOR-encrypted traffic.

Exfiltration

Via C2 channel after data collection.

Impact Analysis

Long-term espionage tool targeting gaming, technology, and pharmaceutical industries. Provides persistent remote access enabling data theft, surveillance, and further compromise.

Indicators of Compromise (IOCs)

Type	Indicator
Service Name	wind0ws
DLL Name	ASPNET_FILTER.DLL (masquerading)
C2 Protocol	HTTP/S, Custom TCP

Type	Indicator
------	-----------

Encryption	XOR
------------	-----

Detection & Mitigation

Detection	Method
-----------	--------

Unusual DLL Load	Monitor rundll32 loading non-standard DLLs
------------------	--

Svchost Service	Monitor new svchost-associated services
-----------------	---

Encrypted C2	Behavioral detection of custom TCP channels
--------------	---

Mitigation	Application whitelisting, monitor registry for new services, EDR behavioral detection
-------------------	---

References

- MITRE ATT&CK: <https://attack.mitre.org/software/S0141/>
- Kaspersky: <https://securelist.com/winnti-more-than-just-a-game/37029/>
- Novetta Analysis:
https://web.archive.org/web/20150412223949/http://www.novetta.com/wp-content/uploads/2015/04/novetta_winntianalysis.pdf

SOFTWARE 3 — S0142: StreamEx

Field	Details
Name	StreamEx
ATT&CK ID	S0142
Type	Malware
Platform	Windows
Version	1.1

Description

StreamEx is a malware family used by Deep Panda since at least 2015. In 2016, it was distributed via legitimate compromised Korean websites. It provides remote command execution and persistence via Windows services.

Threat Actor Association

Actor

Notes

Deep Panda (G0009) Primary user

Supported Platforms

Platform

Windows

ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1059.003	Windows Command Shell	Remotely executes commands
T1543.003	Windows Service	Installs new service pointing to DLL, set to auto-start
T1083	File and Directory Discovery	Enumerates drive types
T1112	Modify Registry	Modifies Windows Registry
T1027	Obfuscated Files	Obfuscates commands with string fragments; XOR 0x91 encoding
T1057	Process Discovery	Enumerates processes
T1518.001	Security Software Discovery	Scans for firewalls and antivirus tools
T1218.011	Rundll32	Uses rundll32 to call exported function
T1082	System Information Discovery	Enumerates system information

Execution Method

Loaded via rundll32.exe calling an exported function.

Persistence Techniques

Installs Windows service (DLL-based, auto-start).

Privilege Escalation

Not specifically documented.

Defense Evasion

String obfuscation, XOR encoding (0x91), rundll32 proxy execution.

Credential Access

Not documented for this malware.

Discovery Techniques

Drive type enumeration, process discovery, security software scanning, system information enumeration.

Lateral Movement

Not specifically documented.

Command & Control

Remote command execution via Windows Command Shell.

Exfiltration

Not specifically documented.

Impact Analysis

Persistent espionage access targeting organizations via compromised Korean websites. Enables long-term reconnaissance and data theft for Deep Panda operations.

Indicators of Compromise (IOCs)

Type	Indicator
Execution	rundll32.exe with non-standard DLL
Encoding	XOR 0x91 obfuscated config

Type	Indicator
Service	Auto-start DLL-based Windows service

Detection & Mitigation

Detection	Method
Rundll32 Abuse	Monitor rundll32 executing unknown DLLs
Service Installation	Alert on new DLL-based auto-start services
Mitigation	Application whitelisting, restrict rundll32 usage, monitor service creation

References

- MITRE ATT&CK: <https://attack.mitre.org/software/S0142/>
- Cylance SPEAR Team: <https://www.cylance.com/shell-crew-variants-continue-to-fly-under-big-avs-radar>

SOFTWARE 4 — S0143: Flame

Field	Details
Name	Flame
ATT&CK ID	S0143
Type	Malware
Associated Names	Flamer, sKyWIper
Platform	Windows
Version	1.1

Description

Flame is a highly sophisticated modular malware toolkit used for cyber espionage, active since at least 2010 and largely targeting Middle East countries. It has extensive capabilities including audio capture, screen capture, Bluetooth surveillance, and USB propagation.

Threat Actor Association

Actor	Notes
Nation-State (suspected Israel/USA)	Based on complexity and targeting of Iran

Supported Platforms**Platform**

Windows

ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1123	Audio Capture	Records audio via hardware recording devices
T1547.002	Authentication Package	Uses Windows Authentication Packages for persistence
T1136.001	Create Local Account	Creates backdoor account "HelpAssistant" on domain systems
T1011.001	Exfiltration Over Bluetooth	BeetleJuice module transmits encoded data via Bluetooth
T1210	Exploitation of Remote Services	Uses MS10-061 print spooler vulnerability for lateral movement
T1036.010	Masquerade Account Name	Creates backdoor account with name "HelpAssistant"
T1091	Replication Through Removable Media	Infects USB sticks using Autorun

Technique ID	Technique Name	Description
T1113	Screen Capture	Takes screenshots when certain applications are open
T1518.001	Security Software Discovery	Identifies antivirus via Security module
T1218.011	Rundll32	Executed via rundll32.exe
T0893 (ICS)	Data from Local System	Collects information from compromised systems
T0882 (ICS)	Theft of Operational Information	Collects AutoCAD, Visio, and operational documents

Execution Method

Executed via rundll32.exe. Has modular architecture — loads various plugins.

Persistence Techniques

Windows Authentication Packages (T1547.002).

Privilege Escalation

Creates local admin backdoor accounts (HelpAssistant).

Defense Evasion

Highly modular — loads only needed components; complex obfuscation.

Credential Access

Backdoor account creation for persistent credential access.

Discovery Techniques

Security software identification, file enumeration from local system.

Lateral Movement

Exploits MS10-061 print spooler vulnerability (T1210), USB propagation via Autorun (T1091).

Command & Control

Bluetooth communication (BeetleJuice module), C2 via network beaconing.

Exfiltration

Exfiltrates via Bluetooth (T1011.001) and C2 channel.

Impact Analysis

One of the most sophisticated espionage tools ever discovered. Targeted critical infrastructure and government systems in Middle East (Iran, Sudan, etc.). Capable of collecting operational data, audio, screenshots, and documents including AutoCAD files.

Indicators of Compromise (IOCs)

Type	Indicator
Account Created	HelpAssistant (backdoor account)
Bluetooth Activity	Unusual Bluetooth beacon signals
USB Activity	Autorun infections
Execution	rundll32.exe with Flame modules

Detection & Mitigation

Detection	Method
Unauthorized Account	Monitor creation of HelpAssistant accounts
Bluetooth Monitoring	Alert on unusual Bluetooth activity
USB Autorun	Disable Autorun; monitor USB insertion
Mitigation	Disable Autorun, monitor local account creation, Bluetooth monitoring, patch MS10-061

References

- MITRE ATT&CK: <https://attack.mitre.org/software/S0143/>
- Kaspersky: <https://securelist.com/the-flame-questions-and-answers-51/34344/>

SOFTWARE 5 — S0144: ChChes

Field	Details
Name	ChChes
ATT&CK ID	S0144
Type	Malware
Associated Names	Scorpion, HAYMAKER
Platform	Windows
Version	1.1

Description

ChChes is a Trojan used exclusively by menuPass (APT10) to target Japanese organizations in 2016. It lacks persistence methods suggesting it is a first-stage tool designed to establish initial C2 and download additional components. It communicates using HTTP with data embedded in Cookie headers.

Threat Actor Association

Actor	Notes
menuPass / APT10 (G0045)	Exclusive user; used in Operation Cloud Hopper

Supported Platforms**Platform**

Windows

ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1071.001	Web Protocols	Communicates via HTTP; embeds data in Cookie header

Technique ID	Technique Name	Description
T1547.001	Registry Run Keys	Establishes persistence via Registry Run key
T1555.003	Credentials from Web Browsers	Steals credentials stored in Internet Explorer
T1132.001	Standard Encoding	Custom Base64 encoding for C2 data
T1573.001	Symmetric Cryptography	Encrypts C2 with AES or RC4
T1083	File and Directory Discovery	Collects %TEMP% path and IE version
T1562.001	Disable or Modify Tools	Can alter victim proxy configuration
T1105	Ingress Tool Transfer	Downloads files and additional modules
T1036.005	Match Legitimate Resource	Copies itself as "notron.exe" mimicking Norton AV
T1057	Process Discovery	Collects PID on victim
T1553.002	Code Signing	Signed with leaked Hacking Team certificate
T1082	System Information Discovery	Collects hostname, screen resolution, Windows version

Execution Method

Delivered via spearphishing; self-replicates as "notron.exe" (Norton AV masquerade).

Persistence Techniques

Registry Run key addition.

Privilege Escalation

Not specifically documented.

Defense Evasion

Masquerading as Norton AV (notron.exe), code signing with leaked certificate, Base64 + AES/RC4 obfuscation.

Credential Access

Steals credentials from Internet Explorer (T1555.003).

Discovery Techniques

File/directory discovery (%TEMP% path), process discovery (PID collection), system information.

Lateral Movement

Not specifically documented — primarily first-stage tool.

Command & Control

HTTP with Cookie header data embedding; Base64 encoded; AES or RC4 encrypted.

Exfiltration

Via C2 channel.

Impact Analysis

First-stage loader for APT10/menuPass operations targeting Japanese academic and government organizations. Used in Operation Cloud Hopper — one of the largest cyber espionage campaigns against managed service providers.

Indicators of Compromise (IOCs)

Type	Indicator
File Name	notron.exe (masquerading Norton AV)
C2 Method	HTTP Cookie header data embedding
Encryption	AES or RC4
Registry	Run key for persistence

Type	Indicator
------	-----------

Detection & Mitigation

Detection	Method
HTTP Anomaly	Detect data in Cookie headers
Code Signing	Alert on certificates from Hacking Team
File Monitoring	Detect notron.exe or similar AV-spoofing names
Mitigation	Block known IOCs, monitor HTTP Cookie anomalies, patch IE vulnerabilities

References

- MITRE ATT&CK: <https://attack.mitre.org/software/S0144/>
- Palo Alto: <https://researchcenter.paloaltonetworks.com/2017/02/unit42-menupass-returns-new-malware-new-attacks-japanese-academics-organizations/>

SOFTWARE 6 — S0145: POWERSOURCE

Field	Details
Name	POWERSOURCE
ATT&CK ID	S0145
Type	Malware
Associated Names	DNSMessenger
Platform	Windows
Version	1.1

Description

POWERSOURCE is a heavily obfuscated PowerShell backdoor, a modified version of the publicly available DNS_TXT_Pwnage tool. Observed in February 2017 in spearphishing campaigns targeting personnel involved with US SEC filings. Delivered when macros were enabled in malicious Office documents, dropping a VBS script.

Threat Actor Association

Actor	Notes
FIN7 (G0046)	Used in SEC filing spearphishing campaigns

Supported Platforms**Platform**

Windows

ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1071.004	DNS	Uses DNS TXT records for C2
T1547.001	Registry Run Keys	Persistence via Registry Run key (user or admin path)
T1059.001	PowerShell	Core PowerShell backdoor
T1564.004	NTFS File Attributes (ADS)	Writes decoded payload to alternate data stream (kernel32.dll)
T1105	Ingress Tool Transfer	Downloads TEXTMATE and Cobalt Strike Beacon
T1012	Query Registry	Queries registry to prepare persistence

Execution Method

Delivered via malicious Office document; macros enable VBS drop; PowerShell execution.

Persistence Techniques

Registry Run key (path varies based on user/admin privileges).

Privilege Escalation

Not specifically documented.

Defense Evasion

NTFS Alternate Data Streams (ADS) to hide payload; heavy obfuscation of PowerShell code.

Credential Access

Not directly — used as downloader for second-stage tools.

Discovery Techniques

Registry querying for persistence preparation.

Lateral Movement

Not directly — enables delivery of lateral movement tools (Cobalt Strike).

Command & Control

DNS TXT records (T1071.004) — covert, difficult to detect channel.

Exfiltration

Via second-stage tools downloaded by POWERSOURCE.

Impact Analysis

First-stage backdoor enabling delivery of Cobalt Strike and TEXTMATE for further compromise of financial sector organizations. Notably uses DNS for C2 — very difficult to block compared to HTTP-based C2.

Indicators of Compromise (IOCs)

Type	Indicator
C2 Method	DNS TXT record queries
ADS Path	%PROGRAMDATA%\Windows\kernel32.dll (alternate data stream)
Registry	Run key — Windows Update naming
Execution	PowerShell with heavy obfuscation

Detection & Mitigation

Detection	Method
DNS Monitoring	Alert on unusual DNS TXT record queries
ADS Detection	Scan for alternate data streams in %PROGRAMDATA%
PowerShell Logging	Enable PowerShell ScriptBlock logging
Mitigation	Disable macros in Office, monitor DNS anomalies, enable PowerShell CLM

References

- MITRE ATT&CK: <https://attack.mitre.org/software/S0145/>
- FireEye:
https://web.archive.org/web/20180808125108/https://www.fireeye.com/blog/threat-research/2017/03/fin7_spear_phishing.html

SOFTWARE 7 — S0146: TEXTMATE

Field	Details
Name	TEXTMATE
ATT&CK ID	S0146
Type	Malware
Associated Names	DNSMessenger (Stage 4)
Platform	Windows
Version	1.1

Description

TEXTMATE is a second-stage, memory-resident PowerShell backdoor. It is entirely fileless — operating only in memory. Observed alongside

POWERSOURCE in February 2017 campaigns. It uses DNS TXT records for C2 and executes cmd.exe to provide a reverse shell.

Threat Actor Association

Actor	Notes
FIN7 (G0046)	Used alongside POWERSOURCE

Supported Platforms

Platform

Windows

ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1071.004	DNS	Uses DNS TXT records for C2
T1059.003	Windows Command Shell	Executes cmd.exe to provide reverse shell to adversaries

Execution Method

Memory-resident; loaded and executed by POWERSOURCE; no disk presence.

Persistence Techniques

None — purely memory-resident (fileless). Relies on POWERSOURCE for persistence.

Privilege Escalation

Not documented.

Defense Evasion

Entirely fileless — memory-resident operation evades file-based detection.

Credential Access

Not directly — provides shell access enabling manual credential theft.

Discovery Techniques

Via interactive reverse shell.

Lateral Movement

Via reverse shell provided to attacker.

Command & Control

DNS TXT records (T1071.004).

Exfiltration

Via reverse shell (cmd.exe) over DNS channel.

Impact Analysis

Provides adversary with fully interactive reverse shell over DNS. Extremely difficult to detect due to memory-only, fileless execution. Enables complete system compromise without file system artifacts.

Indicators of Compromise (IOCs)

Type	Indicator
C2 Method	DNS TXT record queries
Execution	Memory-resident PowerShell; cmd.exe reverse shell
File Artifacts	None (fileless)

Detection & Mitigation

Detection	Method
Memory Scanning	Scan for malicious PowerShell in memory
DNS TXT Monitoring	Alert on unusual DNS TXT record queries
CMD Spawning	Monitor cmd.exe spawned by PowerShell
Mitigation	PowerShell Constrained Language Mode, DNS monitoring, memory-based EDR

References

- MITRE ATT&CK: <https://attack.mitre.org/software/S0146/>

- FireEye:
https://web.archive.org/web/20180808125108/https://www.fireeye.com/blog/threat-research/2017/03/fin7_spear_phishing.html

SOFTWARE 8 — S0147: Pteranodon

Field	Details
Name	Pteranodon
ATT&CK ID	S0147
Type	Malware
Associated Names	Pterodo
Platform	Windows
Version	2.1

Description

Pteranodon is a custom backdoor used by Gamaredon Group (Russian state-sponsored) targeting Ukrainian government and military. It captures screenshots at configurable intervals, exfiltrates them to C2, and downloads additional payloads. It has anti-sandbox detection capabilities.

Threat Actor Association

Actor	Notes
Gamaredon Group / Shuckworm (G0047)	Primary user — Russian state-sponsored

Supported Platforms

Platform

Windows

ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1071.001	Web Protocols	Uses HTTP for C2
T1547.001	Registry Run Keys / Startup	Copies itself to Startup folder
T1059.003	Windows Command Shell	Uses cmd.exe for execution
T1059.005	Visual Basic	Uses malicious VBS files
T1074.001	Local Data Staging	Creates subdirectories under %Temp%\reports%
T1140	Deobfuscate/Decode	Decrypts encrypted data strings
T1041	Exfiltration Over C2	Exfiltrates screenshots to C2
T1083	File and Directory Discovery	Identifies files by extension
T1070.004	File Deletion	Deletes interfering files and itself after execution
T1105	Ingress Tool Transfer	Downloads and executes additional files
T1106	Native API	Uses various Windows API calls
T1027.007	Dynamic API Resolution	Uses dynamic Windows hashing to map API
T1053.005	Scheduled Task	Schedules tasks for persistence
T1113	Screen Capture	Captures screenshots at configurable interval
T1218.005	Mshta	Uses mshta.exe to execute remote HTA files
T1218.011	Rundll32	Executes functions via rundll32.exe
T1497	Virtualization/Sandbox Evasion	Anti-detection for sandbox environments

Execution Method

Delivered via spearphishing; VBS/HTA files execute via mshta.exe or rundll32.exe.

Persistence Techniques

Startup folder copy (T1547.001), Scheduled tasks (T1053.005).

Privilege Escalation

Not specifically documented.

Defense Evasion

File self-deletion, dynamic API resolution, sandbox evasion, VBS obfuscation.

Credential Access

Not directly documented.

Discovery Techniques

File discovery by extension, local data staging in temp directories.

Lateral Movement

Not specifically documented — primarily surveillance tool.

Command & Control

HTTP (T1071.001).

Exfiltration

Screenshots exfiltrated over C2 channel (T1041).

Impact Analysis

Long-running surveillance tool used by Russia-linked Gamaredon Group primarily against Ukraine. Enables persistent screen capture and file exfiltration, significantly supporting intelligence operations against military and government targets.

Indicators of Compromise (IOCs)

Type	Indicator
Staging Path	%Temp%\reports% subdirectories
Screenshot Path	C:\Users\AppData\Roaming\Microsoft\store\ (JPEG files)

Type	Indicator
C2 Protocol	HTTP
Execution	mshta.exe, rundll32.exe, VBS

Detection & Mitigation

Detection	Method
Scheduled Task	Monitor for unusual scheduled task creation
Screenshot Files	Monitor JPEG creation in AppData\Roaming\Microsoft\store
Mshta/Rundll32	Alert on mshta loading remote content
Mitigation	Block mshta from executing remote content, monitor startup folder, scheduled task auditing

References

- MITRE ATT&CK: <https://attack.mitre.org/software/S0147/>
- Palo Alto: <https://researchcenter.paloaltonetworks.com/2017/02/unit-42-title-gamaredon-group-toolset-evolution/>

SOFTWARE 9 — S0148: RTM

Field	Details
Name	RTM (Read The Manual)
ATT&CK ID	S0148
Type	Malware
Associated Names	Redaman
Platform	Windows
Version	1.2

Description

RTM is custom Delphi-based banking malware used by the RTM threat group primarily targeting Russian-speaking financial organizations. It has keylogging, screenshot capture, VNC module, and uses innovative C2 techniques including Bitcoin blockchain and Livejournal RSS feeds for C2 resolution.

Threat Actor Association

Actor	Notes
--------------	--------------

RTM Group (G0048)	Primary user — financially motivated
-------------------	--------------------------------------

Supported Platforms**Platform**

Windows

ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1548.002	Bypass UAC	Shows fake error + legitimate UAC bypass prompt
T1071.001	Web Protocols	Initiates HTTPS connections to external domains
T1119	Automated Collection	Auto-captures screenshots on URL pattern matches
T1547.001	Registry Run Keys	Adds "Windows Update" Registry Run key
T1115	Clipboard Data	Collects clipboard data
T1059.003	Windows Command Shell	Uses cmd.exe and rundll32.exe for execution
T1568	Dynamic Resolution	Resolves C2 via Bitcoin blockchain transactions
T1573.001	Symmetric Cryptography	Custom RC4 variant for C2 encryption

Technique ID	Technique Name	Description
T1083	File and Directory Discovery	Checks for virtualization/analysis-related files
T1070.004	File Deletion	Deletes all files created during execution
T1070.009	Clear Persistence	Removes Registry persistence entries
T1105	Ingress Tool Transfer	Downloads additional files
T1056.001	Keylogging	Records keyboard and virtual keyboard input
T1559.002	Dynamic Data Exchange	Searches browser tabs for specific strings via DDE
T1036	Masquerading	Delivered as archived executables masquerading as PDFs
T1036.004	Masquerade Task	Scheduled task named "Windows Update"
T1112	Modify Registry	Deletes all registry entries created during execution
T1106	Native API	Uses FindNextUrlCacheEntryA for browser history search
T1571	Non-Standard Port	Port 44443 for VNC module
T1027	Obfuscated Files	Modified RC4 encryption for strings and config
T1027.015	Compression	Delivered as ZIP, 7-ZIP, RAR archives
T1120	Peripheral Device Discovery	Obtains list of smart card readers

Technique ID	Technique Name	Description
T1566.001	Spearphishing Attachment	Delivered via spearphishing as PDF-disguised files
T1057	Process Discovery	Obtains process integrity levels
T1219	Remote Access Tools	Downloads VNC module from C2
T1053.005	Scheduled Task	Creates scheduled task for persistence
T1113	Screen Capture	Captures screenshots
T1518	Software Discovery	Scans for banking software
T1518.001	Security Software Discovery	Obtains info about security software
T1553.002	Code Signing	Signed samples observed
T1553.004	Install Root Certificate	Can add certificate to Windows store
T1218.011	Rundll32	Runs core DLL via rundll32.exe
T1082	System Information Discovery	Obtains computer name, OS version, language
T1033	System Owner/User Discovery	Obtains username and permissions
T1124	System Time Discovery	Obtains victim time zone
T1204.002	Malicious File	Relies on user executing malicious attachment
T1497	Virtualization/Sandbox Evasion	Detects sandbox/virtual environments
T1102.001	Dead Drop Resolver	Uses Livejournal RSS + Bitcoin/Namecoin blockchain for C2

Execution Method

Delivered via spearphishing attachment (ZIP/RAR/7ZIP archive disguised as PDF); user double-clicks executable.

Persistence Techniques

Registry Run key ("Windows Update"), Scheduled Task ("Windows Update").

Privilege Escalation

UAC bypass via social engineering — shows fake error + legitimate UAC prompt (T1548.002).

Defense Evasion

File deletion of all created files, registry cleanup, code signing, sandbox detection, RC4 encryption, masquerading as PDFs.

Credential Access

Keylogging (keyboard + virtual keyboard), clipboard data, credential theft via browser history.

Discovery Techniques

File/directory discovery for virtualization detection, banking software scanning, security software detection, peripheral device (smart card) discovery.

Lateral Movement

Not primarily documented — focuses on banking credential theft.

Command & Control

HTTPS (T1071.001), Bitcoin/Namecoin blockchain C2 resolution, Livejournal RSS dead drop, custom RC4-encrypted, non-standard port 44443 (VNC).

Exfiltration

Via C2 channel — screenshots, keylogs, clipboard data.

Impact Analysis

Sophisticated financially motivated malware targeting Russian banking clients. Uses highly innovative C2 techniques (blockchain-based) making takedown extremely difficult. Installation of root certificates enables MITM attacks against banking SSL connections.

Indicators of Compromise (IOCs)

Type	Indicator
Registry	HKCU...\Run\Windows Update
Scheduled Task	Windows Update
C2 Port	44443 (VNC)
Delivery	ZIP/RAR/7ZIP archive with EXE
Encryption	Modified RC4

Detection & Mitigation

Detection	Method
Blockchain C2 Monitor	unusual DNS/blockchain queries
Keylogging	Behavioral detection of keyboard hook APIs
Archive Emails	Scan compressed attachments for executables
Mitigation	Email filtering, disable macro execution, monitor smart card readers, EDR

References

- MITRE ATT&CK: <https://attack.mitre.org/software/S0148/>
- ESET: <https://www.welivesecurity.com/wp-content/uploads/2017/02/Read-The-Manual.pdf>

SOFTWARE 10 — S0149: MoonWind

Field	Details
Name	MoonWind
ATT&CK ID	S0149

Field	Details
Type	Malware
Platform	Windows
Version	1.1

Description

MoonWind is a Remote Access Tool (RAT) used in 2016 to target organizations in Thailand, specifically Thai utility organizations. It communicates via raw sockets over common ports (80, 443, 53, 8080) while encrypting traffic with RC4. Notable for its self-healing service mechanism that respawns the malware every 60 seconds.

Threat Actor Association

Actor	Notes
Unidentified China-linked Actor	Targeted Thai utility sector alongside Trochilus RAT

Supported Platforms

Platform

Windows

ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1059.003	Windows Command Shell	Executes commands via interactive command shell and batch scripts
T1543.003	Windows Service	Installs auto-start service; checks every 60 seconds to respawn
T1074.001	Local Data Staging	Saves keylog data as .zip file in working directory
T1573.001	Symmetric Cryptography	Encrypts C2 traffic with RC4 static key

Technique ID	Technique Name	Description
T1083	File and Directory Discovery	Returns directory listing for specified directories
T1070.004	File Deletion	Deletes itself or specified files
T1056.001	Keylogging	Has built-in keylogger
T1095	Non-Application Layer Protocol	Communicates via raw sockets
T1571	Non-Standard Port	Uses ports 80, 443, 53, 8080 via raw sockets (not standard protocols)
T1120	Peripheral Device Discovery	Obtains number of removable drives
T1057	Process Discovery	Returns list of running processes
T1082	System Information Discovery	Obtains hostname, Windows version, RAM, screen resolution
T1016	System Network Config Discovery	Obtains victim IP address
T1033	System Owner/User Discovery	Obtains victim username
T1124	System Time Discovery	Obtains victim's current time

Execution Method

Installs itself as a Windows service with automatic startup.

Persistence Techniques

Windows service (auto-start, checks every 60 seconds to respawn — T1543.003).

Privilege Escalation

Not specifically documented.

Defense Evasion

Uses common ports (80, 443, 53, 8080) via raw sockets to blend with legitimate traffic; RC4 encryption.

Credential Access

Keylogging (keyboard + virtual) — saves as .zip file.

Discovery Techniques

Directory listing, process list, system info, network config, peripheral (removable drive) discovery.

Lateral Movement

Not specifically documented.

Command & Control

Raw sockets over ports 80, 443, 53, 8080 with RC4 static key encryption.

Exfiltration

Via C2 channel; keylogs staged locally as .zip before exfiltration.

Impact Analysis

Targeted Thai utility sector infrastructure. Self-healing service mechanism ensures persistence even if process is killed. Keylogging and system discovery capabilities enable comprehensive espionage against critical infrastructure targets.

Indicators of Compromise (IOCs)

Type	Indicator
Service	Auto-start Windows service with 60-second watchdog
C2 Ports	80, 443, 53, 8080 via raw sockets
Encryption	RC4 static key
Keylog File	.zip file in working directory

Detection & Mitigation

Detection	Method
Raw Socket Traffic	Deep packet inspection on common ports
Service Watchdog	Alert on services that repeatedly respawn processes
Keylog .zip	Monitor .zip creation in unusual directories
Mitigation	Network DPI, monitor Windows service creation, restrict raw socket usage

References

- MITRE ATT&CK: <https://attack.mitre.org/software/S0149/>
- Palo Alto: <http://researchcenter.paloaltonetworks.com/2017/03/unit42-trochilus-rat-new-moonwind-rat-used-attack-thai-utility-organizations/>

SOFTWARE 11 — S0150: POSHSPY

Field	Details
Name	POSHSPY
ATT&CK ID	S0150
Type	Malware
Platform	Windows
Version	1.2

Description

POSHSPY is a secondary/backup PowerShell backdoor used by APT29 (Cozy Bear/Russian SVR) since at least 2015. It was used as a fallback when primary backdoors were lost. Notable for its use of WMI event subscription for

persistence — an extremely stealthy fileless persistence mechanism. All C2 traffic is encrypted with AES and RSA.

Threat Actor Association

Actor

Notes

APT29 / Cozy Bear (G0016) Russian SVR-linked; used as secondary backdoor

Supported Platforms

Platform

Windows

ATT&CK Techniques Used

Technique ID	Technique Name	Description
T1059.001	PowerShell	Uses PowerShell to execute commands and payload
T1030	Data Transfer Size Limits	Uploads data in 2048-byte chunks
T1568.002	Domain Generation Algorithms	Uses DGA to derive C2 URLs from word list
T1573.002	Asymmetric Cryptography	Encrypts C2 traffic with AES and RSA
T1546.003	WMI Event Subscription	Uses WMI event subscription for persistence
T1070.006	Timestomp	Modifies downloaded file timestamps to pre-2013 dates
T1105	Ingress Tool Transfer	Downloads and executes additional PowerShell and Windows binaries
T1027	Obfuscated Files	Appends fake file signature headers to encrypted data

Execution Method

PowerShell-based; triggered via WMI event subscription.

Persistence Techniques

WMI Event Subscription (T1546.003) — extremely stealthy, survives reboots, very difficult to detect.

Privilege Escalation

Not specifically documented.

Defense Evasion

Timestomping (pre-2013 dates), fake file headers on encrypted data, DGA-based C2, WMI-based fileless persistence.

Credential Access

Not directly documented — used as access maintainer for APT29 operations.

Discovery Techniques

Not specifically documented.

Lateral Movement

Not specifically documented — secondary access maintainer.

Command & Control

DGA-derived URLs (T1568.002); AES + RSA encrypted (T1573.002).

Exfiltration

Data uploaded in 2048-byte chunks via C2 channel.

Impact Analysis

Critical secondary backdoor for APT29 ensuring continued access even after primary backdoor removal. WMI event subscription persistence is extremely difficult to detect and remove. AES+RSA encryption makes C2 traffic analysis very difficult. Used against high-value government and political targets.

Indicators of Compromise (IOCs)

Type	Indicator
Persistence	WMI Event Subscription
C2 Method	DGA-generated URLs
Encryption	AES + RSA
Upload Chunks	2048-byte data transfers
File Timestamps	Modified to pre-2013 dates

Detection & Mitigation

Detection	Method
WMI Subscription	Monitor WMI event subscriptions (Get-WMIObject)
Timestomping	Alert on files with suspicious pre-2013 timestamps
DGA Detection	ML-based domain name entropy analysis
PowerShell	Enable full PowerShell logging
Mitigation	WMI activity monitoring, PowerShell CLM, EDR with WMI visibility, AV with behavioral detection

References

- MITRE ATT&CK: <https://attack.mitre.org/software/S0150/>
- FireEye: https://www.fireeye.com/blog/threat-research/2017/03/dissecting_one_ofap.html

Document Prepared By: *(Bhoomi Sanjay Wadke)* **Intern ID:** *(2114)* **Software Range:** S0140 – S0150 **Submission Date:** 15 May 2026
